

AppFueled Security Overview

ReferACar, LLC dba AppFueled | 5465 E Terra Linda Way, Nampa, ID 83687

Document version: 1.0 **Effective date:** September 9, 2026

Owner: Jeremy Glassco, Founder and CEO **Review cycle:** Annual

Classification: Shareable with clients and their security reviewers

1. Purpose and Scope

This document describes the security posture of the AppFueled platform, the hosted software as a subscription service operated by ReferACar, LLC dba AppFueled for independent automotive repair shops. It is provided to clients and their security reviewers as a plain language summary of how the platform is built, accessed, monitored and maintained.

Scope covers the AppFueled web application and CRM, the SideKick Ninja browser extension, the branded customer mobile applications, the Call Center Concierge telephony and messaging suite, the My Oil Sticker printing software, and the shop management system integrations that support them. It does not cover client owned equipment, client networks, or third party systems outside AppFueled control.

2. Company and Platform Summary

Item	Detail
Legal entity	ReferACar, LLC, an Idaho limited liability company, dba AppFueled
Address	5465 E Terra Linda Way, Nampa, ID 83687
Service model	Multi tenant software as a subscription, delivered over the public internet
Client base	Independent automotive repair shops in the United States and Canada
Hosting	Amazon Web Services, US East (Ohio), us-east-2
Data residency	United States
Security contact	jeremyg@appfueled.com
Public policies	https://appfueled.io/privacy and https://appfueled.io/terms

3. Independent Security Assessment

AppFueled has undergone an independent security assessment sponsored by the Boise State University cybersecurity program.

- **Sponsor:** Boise State University cybersecurity program
- **Date performed:** March 2025
- **Scope:** AppFueled web application
- **Remediation status:** Findings remediated

A summary of the assessment can be shared with clients under a mutual non disclosure agreement on request.

4. Access Control and Authentication

4.1 Client user access

- Users access AppFueled through the secure web application over an encrypted connection. There is no on premise server component to install or patch.
- Two factor authentication is required for web application accounts.
- Access is role based. Shop administrators can create, modify and disable user accounts for their own location.
- Passwords are stored using one way cryptographic hashing. AppFueled staff cannot retrieve a user password.
- Account holders are responsible for managing their credentials and for notifying AppFueled of any suspected unauthorized access, per Section 9.4 of the service agreement.

4.2 Internal and administrative access

- All internal and administrative access to AppFueled systems is restricted to a WireGuard VPN. Administrative interfaces are not exposed to the open internet.
- Seven individuals currently hold production access, including contractors engaged by AppFueled.
- Access is granted on a least privilege basis and limited to personnel whose role requires it.
- Access is reviewed periodically and revoked when a team member changes role, departs, or completes a contract engagement.
- Client data is accessed by AppFueled personnel only for support, troubleshooting, provisioning and platform operation.

4.3 Tenant separation

AppFueled is a multi tenant platform. Each client account is logically isolated, and application level authorization checks prevent one tenant from reading or writing another tenant record. Telephony and messaging resources are provisioned per client under separate carrier subaccounts.

5. Encryption

Layer	Control
Data in transit, external	All external access is encrypted using SSL/TLS, terminated at the Cloudflare edge and enforced to the application.
Data in transit, internal	Administrative and internal traffic traverses a WireGuard VPN.
Data at rest	Amazon RDS storage encryption enabled on the production database, using AES-256 with AWS Key Management Service.
Backups	Automated RDS backups and snapshots inherit encryption from the encrypted database instance.

Layer	Control
Credentials	Passwords stored as one way cryptographic hashes. API keys and integration secrets stored encrypted.
Mobile applications	App to platform communication is over TLS. No payment card data is stored on the device.

6. Payment Card Handling and PCI

AppFueled payment processing is PCI DSS compliant. Subscription billing is handled through Authorize.net and Stripe, both PCI DSS compliant payment processors. Card data is tokenized by the processor. AppFueled stores only the resulting token and non sensitive card metadata, and AppFueled personnel have no access to full card numbers.

- **Payment processors:** Authorize.net and Stripe
- **Compliance posture:** SAQ A scope. Card data is fully outsourced to the processors and is not transmitted through, processed by, or stored on AppFueled systems in unencrypted form.
- **Card data storage:** Processor tokenization. No full card numbers in the AppFueled database.

AppFueled does not process a shop's in store customer payment transactions. The shop point of sale and shop management system remain the systems of record for customer payments.

7. Application and Endpoint Security

7.1 Web application

- Input validation and output encoding are applied to defend against injection and cross site scripting.
- Session management uses secure, HTTP only cookies with session expiry.
- Cloudflare sits in front of the application, providing rate limiting and country based access restrictions at the edge.
- Dependencies are monitored and updated as security patches are released.
- Code changes are reviewed before release to production.
- Platform updates are delivered continuously to the hosted service, so all clients run the current supported version. There is no client managed patching burden.

7.2 SideKick Ninja Chrome extension

- The extension is distributed through the Chrome Web Store and is subject to Google review and Manifest V3 requirements.
- It is installed per user on the user workstation, so install dates vary by user rather than being a single site wide deployment.
- It requests only the permissions needed to operate at the service counter and communicates with AppFueled over TLS.
- It authenticates to the same account as the web application, so disabling a user account also revokes extension access.

7.3 Mobile applications

- Branded consumer apps are published through the Apple App Store and Google Play and are subject to each store review process.
- The Apple Developer Program license is held and renewed by the client, per Section 9.5 of the service agreement.

8. Hosting and Infrastructure

Item	Detail
Hosting provider	Amazon Web Services
Region	US East (Ohio), us-east-2
Database	Amazon RDS with storage encryption enabled
Provider certifications	AWS maintains SOC 2, SOC 3 and ISO 27001 certifications for its infrastructure. Reports are published by AWS.
Edge protection	Cloudflare, with rate limiting and country based access restrictions enabled
Network controls	Restricted ingress. Administrative access reachable only over the WireGuard VPN.
Monitoring	Platform and database metrics collected through Amazon CloudWatch
Log retention	Application and infrastructure logs retained per AWS default configuration

9. Backup, Recovery and Availability

Item	Detail
Backup method	Amazon RDS automated backups, logged daily
Point in time recovery	Enabled
Backup retention	7 days
Backup encryption	Inherited from the encrypted database instance
Recovery point objective (RPO)	5 minutes
Recovery time objective (RTO)	4 hours
Client self service export	Available at any time through the application

Clients are encouraged to retain independent copies of records they consider critical.

10. Data Retention, Export and Deletion

Data handling on termination is governed by Section 9.7 of the service agreement:

- Account data, including customer contact records, service history and communication logs, remains available for self service export for thirty (30) days after the effective termination or cancellation date.
- The client is responsible for exporting any data it wishes to retain within that window.
- After thirty (30) days, AppFueled may permanently delete the account data.
- AppFueled makes no guarantee as to the format, completeness or compatibility of exported data with any third party system.

Deletion requests from consumers whose data a client holds in AppFueled are handled per the published privacy policy at <https://appfueled.io/privacy>. AppFueled acts as a service provider to the shop, which remains the controller of its own customer data.

11. Messaging, Telephony and Regulatory Compliance

Text messaging and calling are delivered through registered carrier infrastructure. Responsibilities are divided as follows, per Section 9.6 of the service agreement.

Responsibility	AppFueled	Client
Platform infrastructure and carrier connectivity	Yes	No
A2P 10DLC brand and campaign registration	Submits and manages	Provides business details
Opt out handling mechanism in the platform	Provides	Must honor opt outs
Obtaining prior express written consent from recipients	No	Yes
Content, recipients and timing of messages	No	Yes
Maintaining records of consent	No	Yes
Call recording notice and consent where required by state law	Provides the tooling	Sets the policy

Call recording laws vary by state. Clients operating in all party consent states should configure recording notifications accordingly.

12. Subprocessors

AppFueled uses the following subprocessors to deliver the service. This list is current as of the effective date and is available on request.

Purpose	Provider
Cloud hosting, database and storage	Amazon Web Services (us-east-2)
Edge protection, CDN and TLS termination	Cloudflare
Voice, SMS and MMS delivery, A2P 10DLC registration	Twilio

Purpose	Provider
Payment processing and card tokenization	Authorize.net, Stripe
Speech to text transcription	Deepgram
AI assisted workflows and language models	Anthropic, OpenAI
Transactional and campaign email delivery	SendGrid, Mandrill
Shop management system integrations (client authorized)	Tekmetric, Shop-Ware, Protractor, R.O. Writer

Shop management system integrations operate only with credentials or API access the client authorizes, and can be revoked by the client at any time.

13. Use of Client Data

- Client data is used to deliver and support the Services.
- AI and speech services are accessed through the providers' commercial APIs. Under the standard API terms of Anthropic and OpenAI, data submitted through the API is not used to train their models.
- AppFueled may combine non identifiable, aggregated data across users to improve the platform and produce benchmarking insights, as described in Sections 7 and 9.2 of the service agreement and in the privacy policy.
- AppFueled does not sell client customer lists.
- AppFueled will not use a client name or business in external marketing materials without prior written consent, per Section 8.3 of the service agreement.

14. Personnel and Operational Practices

- Seven individuals, including contractors, currently hold production access.
- Personnel and contractors with production access are bound by confidentiality obligations.
- Contractors are granted only the access their engagement requires, and access is removed at the end of the engagement.
- Security awareness expectations, including phishing vigilance and credential hygiene, are communicated to all personnel.
- Code changes are reviewed before release to production.

15. Incident Response

AppFueled maintains an incident response process covering detection, containment, eradication, recovery and client notification.

- **Triage owner:** Jeremy Glassco, Founder and CEO
- **Client notification:** Within 72 hours of confirming an incident affecting client data
- **Post incident:** Written summary of cause, impact and corrective action provided to affected clients
- **Regulatory notification:** Handled per applicable state breach notification law

Report a suspected security issue to jeremyg@appfueled.com.

16. Contractual Security and Legal Terms

Topic	Where it is addressed
Privacy and data use	Service agreement Sections 7 and 9.2, and the published privacy policy
Client content responsibility	Service agreement Section 8.1
SMS and TCPA responsibility	Service agreement Section 9.6
Data handling on termination	Service agreement Section 9.7
Warranty disclaimer	Service agreement Section 10
Limitation of liability	Service agreement Section 11, capped at fees paid in the prior three months
Governing law and disputes	Service agreement Sections 14 and 15, Idaho law, AAA arbitration

17. Documents Available on Request

- Summary of the independent security assessment, under mutual non disclosure agreement
- Current subprocessor list
- Completed vendor security questionnaire in the client format
- Certificate of insurance
- Data processing addendum

Requests: jeremyg@appfueled.com

This document describes controls in place as of the effective date above and is provided for informational purposes. It does not amend the AppFueled Software as a Subscription Agreement. Where this document and the executed agreement differ, the agreement controls.